Zero Trust Network Access (ZTNA) with Zscaler: Enhancing Secure User-to-Application Access.

S.No	NAME	COLLEGE NAME	CONTACT
1.	ARJUN R K	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs107arjunrk@skacas.ac.in
2.	KAVYASHREE S	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs125kavyashrees@skacas.ac.in
3.	NAVEENA T	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs134naveenat@skacas.ac.in
4.	MADHAVAN S	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs129madhavans@skacas.ac.in
5.	KRISHNA RAJ R	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs126krishnarajr@skacas.ac.in

Project details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Enhancing Secure User-to-Application Access

• AI-Enhanced User Protection (AIUP)

AI-Enhanced User Protection (AIUP) is an advanced security capability integrated within the Zero Trust Network Access (ZTNA) framework to improve protection for users accessing enterprise applications. Traditional security systems rely on static rules and signatures to identify threats. However, modern cyber threats are highly dynamic and sophisticated. AIUP leverages Artificial Intelligence and Machine Learning techniques to continuously analyze user behavior, detect anomalies, and prevent unauthorized access in real time.

In a Zscaler-based ZTNA environment, AIUP strengthens the security posture by monitoring user activity, device posture, and network access patterns. The system collects and processes large volumes of security data from multiple sources such as user authentication logs, device information, and application access records. AI algorithms analyze this data to identify unusual or suspicious behaviors that may indicate potential security threats.

One of the primary advantages of AI-Enhanced User Protection is its ability to detect insider threats and compromised accounts. For example, if a user suddenly attempts to access sensitive applications from an unfamiliar location or device, the AI engine can recognize this anomaly and trigger security actions such as multi-factor authentication, session termination, or access restriction.

AIUP also improves threat intelligence by continuously learning from previous attacks and user behavior patterns. Over time, the system becomes more accurate in identifying malicious activities such as credential theft, brute-force login attempts, and abnormal data transfers. This adaptive learning capability helps organizations stay ahead of evolving cyber threats.

Within the Zscaler Zero Trust architecture, AIUP works in combination with identity-based access policies. Every user request is verified based on identity, device status, and contextual information before granting access to an application. AI further enhances this process by providing risk-based access decisions, ensuring that only legitimate users can connect to enterprise resources.

Additionally, AI-Enhanced User Protection reduces the workload for security administrators by automating threat detection and response. Instead of manually analyzing logs and alerts, administrators can rely on AI-driven insights to quickly identify and mitigate security risks.

Overall, AIUP plays a critical role in strengthening the Zero Trust security model by providing intelligent, adaptive, and proactive protection for users. By integrating AI-driven analytics with Zscaler's cloud security platform, organizations can ensure secure and reliable user-to-application connectivity while minimizing the risk of cyber attacks.

Abstract:

In modern enterprise environments, traditional network security models that rely on perimeter-based defenses are no longer sufficient to protect sensitive data and applications. With the rapid growth of cloud computing, remote work, and mobile devices, organizations require a more secure and flexible approach to access control. Zero Trust Network Access (ZTNA) is an advanced security framework that follows the principle of "never trust, always verify," ensuring that every user and device must be authenticated and authorized before accessing any application or resource.

This project focuses on implementing ZTNA using the Zscaler platform to provide secure, identity-based access to enterprise applications without exposing internal networks. The system ensures that users can only access specific applications based on their identity, device posture, and security policies. By eliminating traditional VPN-based connectivity, ZTNA significantly reduces the risk of unauthorized access and lateral movement within the network.

Additionally, the project incorporates AI-Enhanced User Protection (AIUP) to strengthen the security model. AI technologies analyze user behavior and detect anomalies in real time, helping to identify suspicious activities such as compromised accounts or unusual login attempts. This intelligent monitoring improves threat detection and enhances the overall security posture of the organization.

The proposed system demonstrates how Zscaler's cloud-native security architecture can be used to provide scalable, secure, and efficient user-to-application connectivity. By combining Zero Trust principles with AI-driven security mechanisms, organizations can ensure continuous protection of their applications and data while maintaining seamless user access.

Use Case Scenarios:

Scenario 1: Remote Employee Access to Internal Application

A remote employee needs to access an internal company application from home using the internet. Using Zscaler ZTNA, the user authenticates through identity verification and device posture checks before accessing the application. The system ensures that the internal network remains hidden while providing secure application connectivity.

Output:

• Secure authentication of the remote employee
• Direct connection established only to the required application
• Internal network infrastructure remains hidden from the user
• Unauthorized access attempts automatically blocked

Scenario 2: Third-Party Vendor Access to Limited Resources

A third-party vendor requires temporary access to a specific internal application for maintenance purposes. Zscaler ZTNA applies identity-based policies and restricts the vendor's access only to the authorized application without exposing other internal systems.

Output:

• Vendor authenticated through secure identity verification
• Access restricted only to the authorized maintenance application
• Other internal systems remain inaccessible
• All activities monitored and logged for security auditing

Scenario 3: Suspicious Login Attempt Detection

A user account attempts to log in from an unfamiliar device and location within a short period. AI-Enhanced User Protection (AIUP) analyzes the login behavior and identifies the activity as suspicious.

Output:

• AI system detects abnormal login behavior
• Additional authentication verification triggered
• Access temporarily restricted until verification is completed
• Security alert generated for administrators

Scenario 4: Secure Access to Cloud Applications

Employees access cloud-based enterprise applications such as internal dashboards or project management systems through Zscaler ZTNA. The system verifies identity and security policies before granting access.

Output:

• Secure identity-based authentication performed
• Access granted only to permitted cloud applications
• Data communication encrypted during the session
• Unauthorized application access automatically blocked

Scenario 5: Protection Against Unauthorized Internal Access

An employee tries to access a restricted internal database that is not assigned to their role. Zscaler ZTNA checks the access policy and prevents the user from reaching the protected resource.

Output:

• User identity and role verified by the policy engine

- Access to restricted database denied
- Attempt logged in the security monitoring system
- Organization’s sensitive data remains protected

Stage-1

Title Of the Project:

Zero Trust Network Access (ZTNA) with Zscaler: Enhancing Secure User-to-Application Access

Overview:

The project focuses on implementing a secure network access model using Zero Trust Network Access (ZTNA) with Zscaler to protect enterprise applications and data from unauthorized access and cyber threats. Traditional network security models rely on perimeter-based protection, which assumes that users inside the network can be trusted. However, with the rise of remote work, cloud services, and mobile devices, this approach is no longer sufficient. ZTNA addresses these challenges by adopting the principle of “never trust, always verify,” ensuring that every user and device must be authenticated and authorized before accessing any application.

The primary objective of this project is to enhance secure user-to-application connectivity by implementing identity-based access control using the Zscaler platform. Instead of providing direct network access, the system connects authenticated users only to the specific applications they are permitted to use. This approach significantly reduces the risk of unauthorized access, data breaches, and lateral movement within the network. The system verifies user identity, device posture, and security policies before granting access to applications. Zscaler’s cloud-based architecture ensures that applications remain hidden from the public internet while allowing secure connectivity for authorized users. By establishing application-level access instead of network-level access, the system strengthens security while maintaining seamless user experience.

AI-Enhanced User Protection (AIUP) is integrated into the system to improve threat detection and response. Artificial intelligence and machine learning techniques are used to analyze user behavior patterns, identify anomalies, and detect suspicious activities such as unusual login attempts or abnormal access patterns. Real-time monitoring enables the system to detect potential threats and automatically trigger additional security measures such as multi-factor authentication or session termination.

Multi-factor authentication is also implemented to strengthen identity verification and ensure that only legitimate users can access enterprise applications. When abnormal behavior is detected, additional verification steps are triggered to confirm the user's identity. User and administrator alerts provide timely notifications about suspicious activities and security events, enabling quick response to potential threats.

Secure data transmission and management are key components of the system. All communication between users and applications is encrypted to protect sensitive information from interception. Logging and monitoring mechanisms are included to track user activities, analyze security events, and generate reports for auditing and compliance purposes.

The system also includes an integration layer that allows seamless connectivity with various enterprise applications, cloud services, and identity providers. Monitoring and reporting tools provide visibility into user access patterns, system performance, and security incidents, ensuring transparency and accountability.

Scalability and high availability are important features of the system. The cloud-based Zscaler architecture is designed to handle large numbers of users and applications without compromising performance. Load balancing and distributed infrastructure ensure that the system can support growing organizational needs.

Security and compliance are prioritized throughout the system design by implementing encryption, secure access policies, intrusion detection mechanisms, and compliance with data protection regulations. Cloud infrastructure further enhances flexibility and scalability, allowing organizations to securely support remote employees and distributed work environments.

Continuous monitoring and policy optimization ensure that the Zero Trust framework adapts to evolving cyber threats and changing user requirements. Geographic distribution of security nodes further enhances reliability, performance, and redundancy by enabling secure access from multiple locations.

Overall, the project demonstrates how the Zscaler Zero Trust Network Access model can provide a secure, scalable, and efficient solution for protecting enterprise applications while ensuring seamless user access in modern digital environments.

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability Name	CWE - No
1	Improper Ownership Management	CWE- 282
2	Cleartext Storage of Sensitive Information in a Cookie	CWE-315
3	Use of Unmaintained Third Party Components	CWE-1104
4	Insufficient Entropy	CWE -331

5	Unchecked Error Condition	CWE-391
6	Embedded Malicious Code	CWE-506
7	Missing Encryption of Sensitive Data	CWE-331
8	Missing XML Validation	CWE -112
9	Missing Critical Step in Authentication	CWE-304
10	Insufficient Logging	CWE-778

REPORT: -

1) Vulnerability Name: Improper Ownership Management

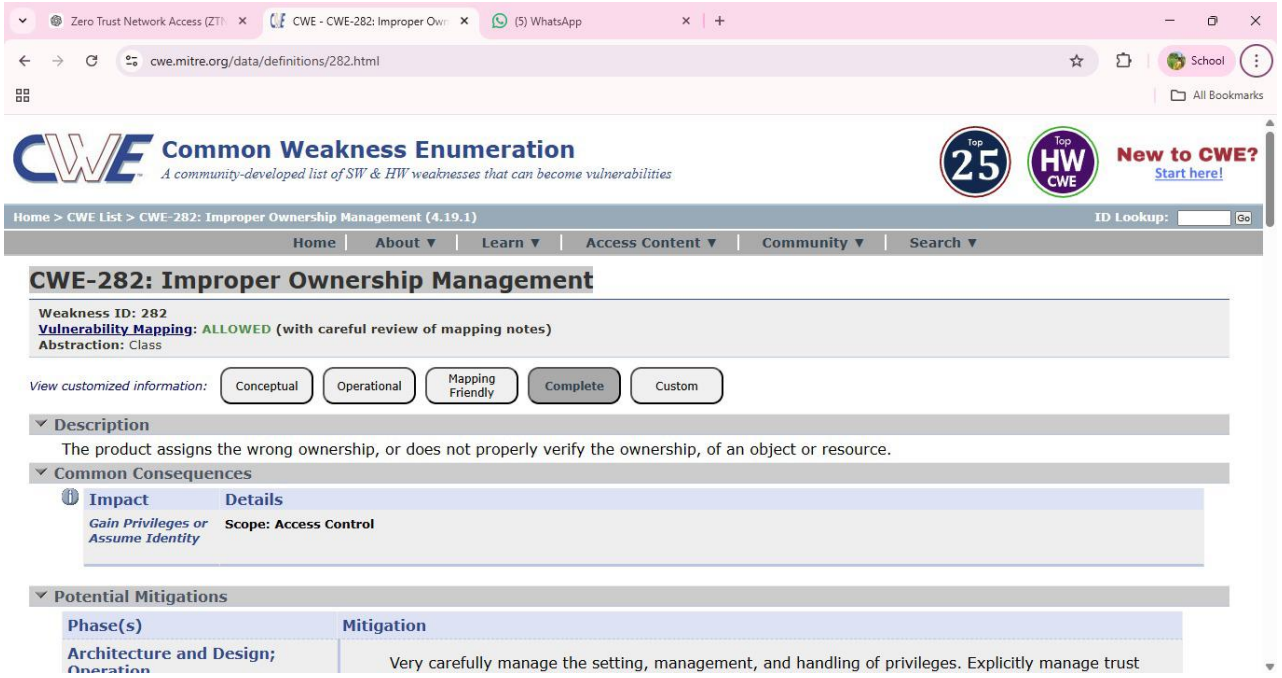
CWE/CVE: CWE-282

OWASP/SANS Category: A01:2025 – Broken Access Control

Description:
Improper Ownership Management occurs when a system fails to correctly assign or enforce ownership permissions for resources such as files, applications, or data. In such situations, unauthorized users may gain the ability to access, modify, or delete resources that should be restricted to specific owners or administrators. This vulnerability often arises due to incorrect configuration of access controls, weak permission management, or improper handling of user roles and privileges. Attackers may exploit this weakness to manipulate ownership settings, leading to unauthorized control over critical system resources.

Business Impact:
If ownership management is not properly enforced, attackers or unauthorized users may gain access to sensitive resources and perform actions that compromise system integrity. This can result in unauthorized modification or deletion of important data, disruption of business operations, and potential data breaches. Additionally, organizations may face financial losses, legal consequences, and

reputational damage if sensitive information or critical systems are compromised due to improper access control mechanisms.



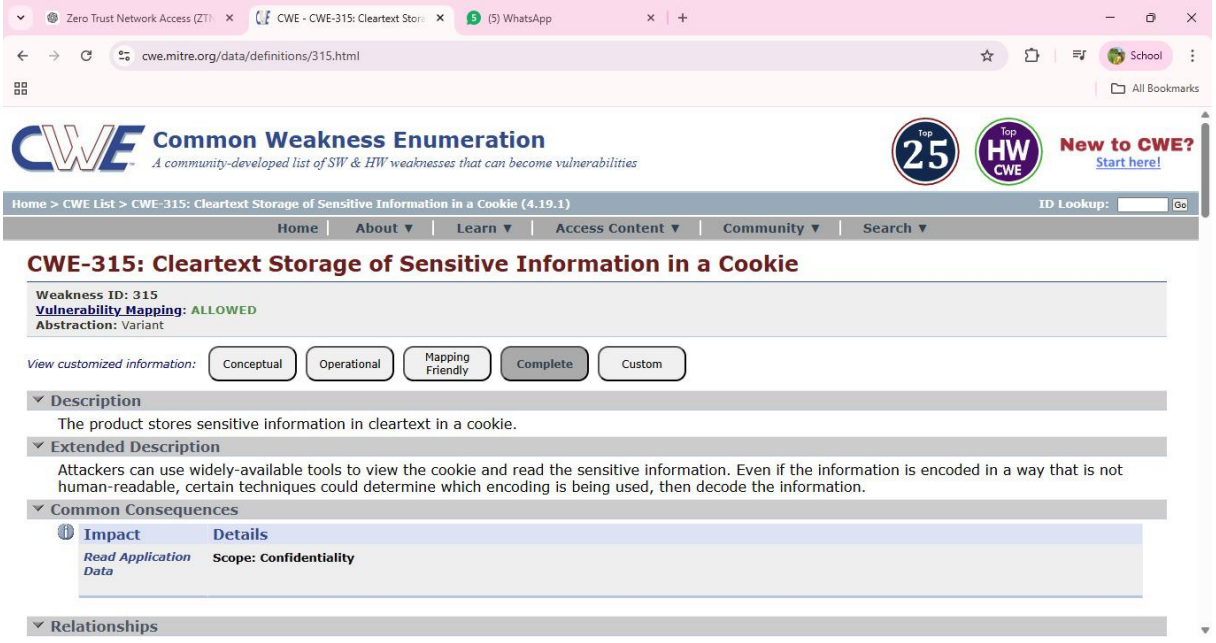
2) Vulnerability Name: Cleartext Storage of Sensitive Information in a Cookie

CWE/CVE: CWE-315

OWASP/SANS Category: A02:2025-Security Misconfiguration

Description:
Cleartext Storage of Sensitive Information in a Cookie occurs when an application stores confidential data such as user credentials, session identifiers, or personal information in browser cookies without encryption. Since cookies are stored on the client side, they can be accessed by attackers through browser vulnerabilities, cross-site scripting (XSS) attacks, or by intercepting network traffic. If sensitive information is stored in plain text, attackers can easily read and misuse the data to gain unauthorized access to user accounts or application resources.

Business Impact:
Storing sensitive information in cleartext cookies can lead to serious security risks such as session hijacking, unauthorized account access, and data breaches. Attackers may impersonate legitimate users and gain access to confidential information or internal systems. This can result in financial loss, legal liabilities, and damage to the organization's reputation, especially if customer or employee data is exposed.



3) Vulnerability Name: Use of Unmaintained Third Party Components

CWE/CVE: CWE-1104

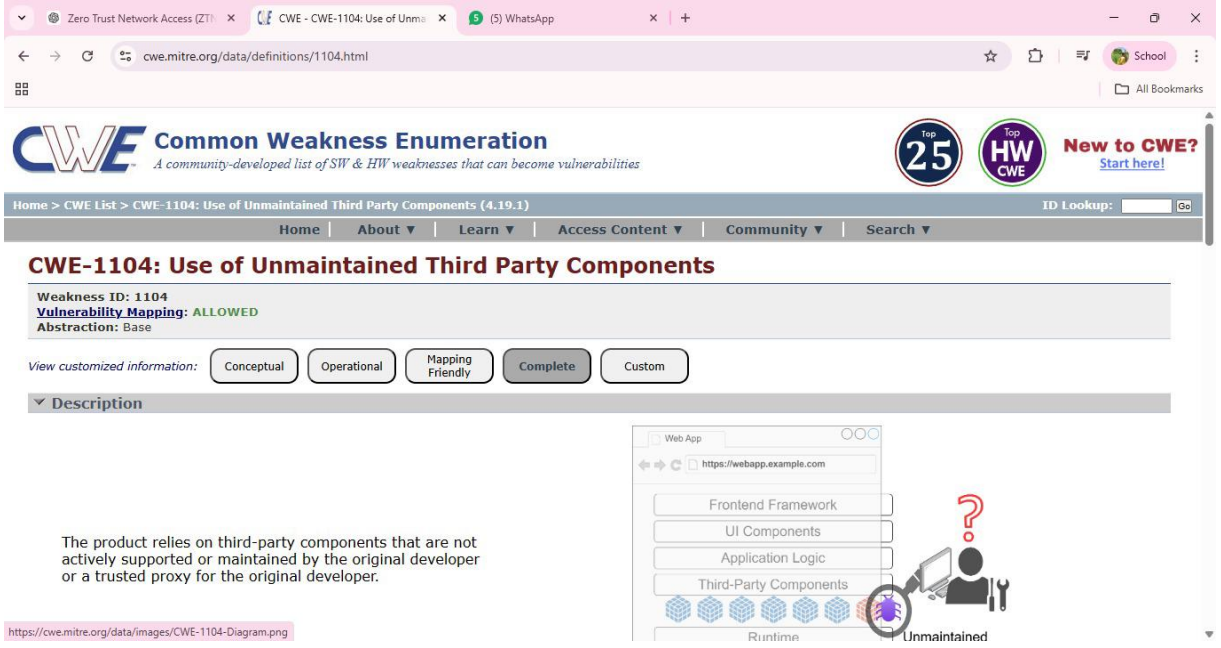
OWASP/SANS Category: A03:2025-Software Supply Chain Failures

Description:

Use of Unmaintained Third Party Components occurs when an application depends on external libraries, frameworks, or software components that are no longer actively maintained or updated by their developers. These outdated components may contain known security vulnerabilities that remain unpatched, making the application susceptible to exploitation. Attackers often scan systems for such components and exploit their weaknesses to gain unauthorized access, execute malicious code, or compromise the system.

Business Impact:

Using unmaintained third-party components can expose an organization to significant security risks. Attackers may exploit known vulnerabilities to compromise applications, leading to data breaches, service disruptions, or unauthorized system access. This can result in financial losses, regulatory compliance issues, and damage to the organization's reputation. Maintaining updated and supported software components is therefore essential for ensuring long-term system security.



4) Vulnerability Name: Insufficient Entropy

CWE/CVE: CWE-331

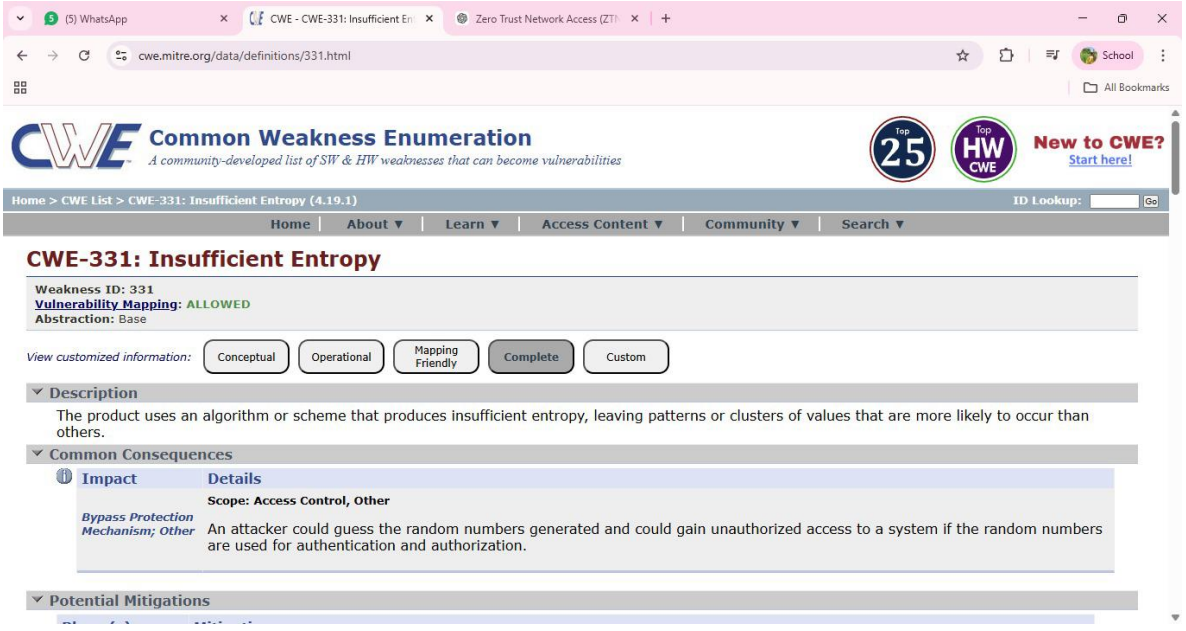
OWASP/SANS Category: A04:2025-Cryptographic Failures

Description:

Insufficient Entropy occurs when a system generates random values, such as cryptographic keys, session IDs, or tokens, using weak or predictable sources of randomness. Entropy refers to the level of unpredictability in generated values. When entropy is insufficient, attackers may be able to predict or reproduce these values, allowing them to bypass security mechanisms. This vulnerability often appears in authentication systems, encryption processes, or session management where strong randomness is required to maintain security.

Business Impact:

If attackers can predict security tokens, session identifiers, or cryptographic keys, they may gain unauthorized access to user accounts or sensitive systems.This can lead to session hijacking, data breaches, and unauthorized transactions. For organizations, such incidents may result in financial losses, legal consequences, and damage to customer trust and reputation. Ensuring strong random number generation is essential to maintain system security.



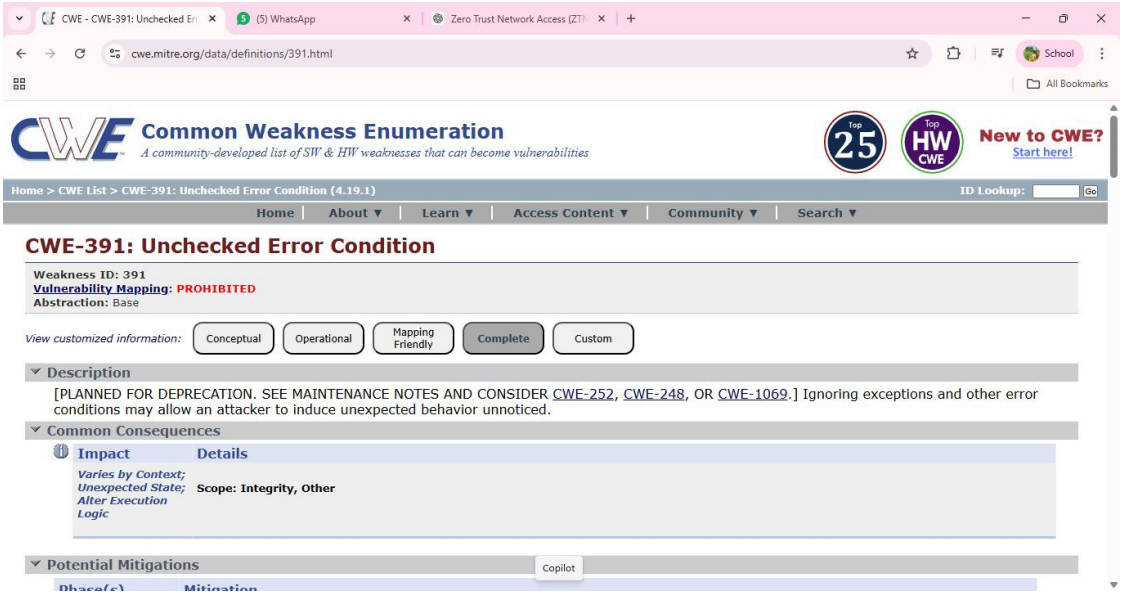
5) Vulnerability Name: Unchecked Error Condition

CWE/CVE: CWE-391

OWASP/SANS Category: A10:2025-Mishandling of Exceptional Conditions

Description:
Unchecked Error Condition occurs when a system or application fails to properly handle errors that occur during program execution. Instead of detecting and responding to these errors appropriately, the system may ignore them or continue processing without taking corrective action. This can lead to unexpected system behavior, incorrect outputs, or security weaknesses. Attackers may exploit such situations to trigger abnormal conditions, potentially bypassing security controls or causing the application to behave in unintended ways.

Business Impact:
Failure to properly handle errors can result in system instability, data corruption, or unauthorized system behavior. Attackers may exploit these weaknesses to disrupt services, manipulate application functionality, or gain access to sensitive information. For organizations, this can lead to operational downtime, financial losses, and damage to reputation due to unreliable or insecure systems. Proper error handling and monitoring mechanisms are essential to maintain application reliability and security.



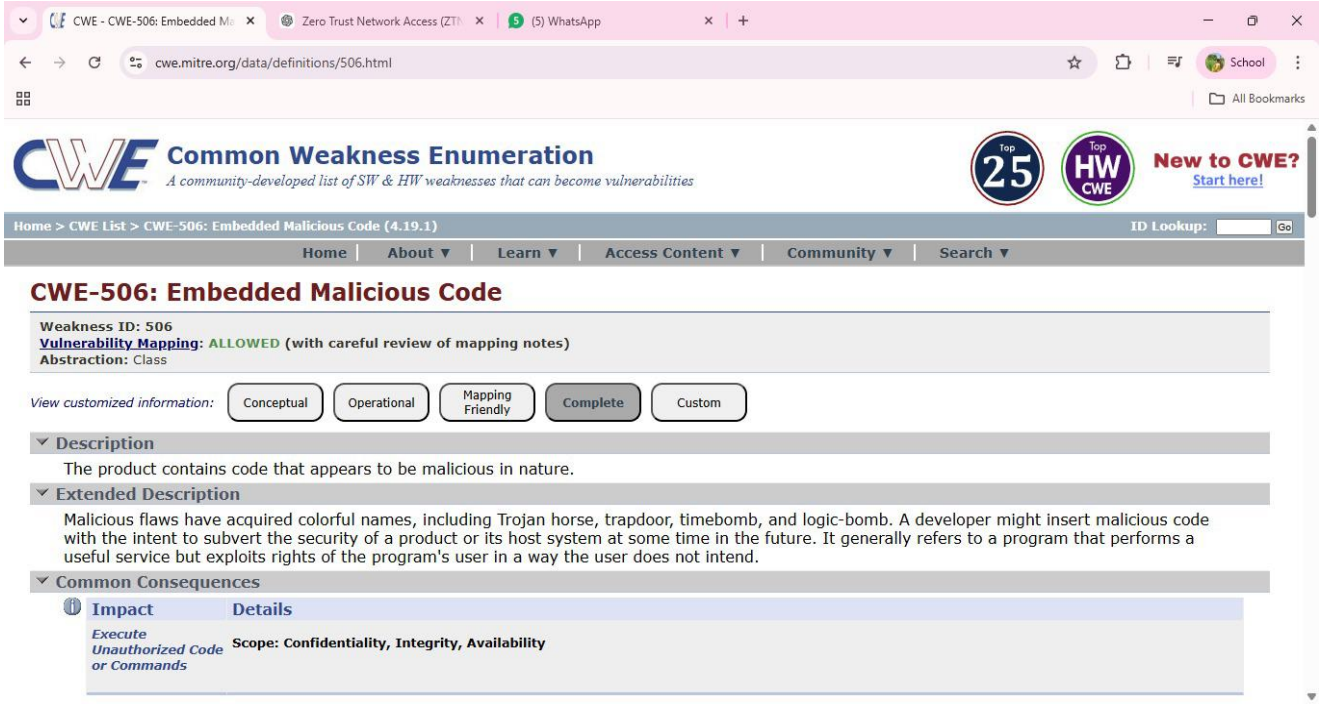
6) Vulnerability Name: Embedded Malicious Code

CWE/CVE: CWE-506

OWASP/SANS Category: A08:2025-Software or Data Integrity Failures

Description:
Embedded Malicious Code refers to the presence of intentionally harmful code hidden within an application or software component. This malicious code may be inserted by attackers, compromised third-party libraries, or during insecure development practices. Such code can perform unauthorized actions such as stealing sensitive information, creating backdoors, or executing harmful operations without the user's knowledge. Because the code is embedded within legitimate software, it may remain undetected for long periods and can be triggered under specific conditions.

Business Impact:
The presence of embedded malicious code can severely compromise the security and reliability of an organization's systems.Attackers may use it to steal confidential data, gain unauthorized access, or disrupt system operations. This can lead to data breaches, financial losses, operational downtime, and reputational damage. In critical environments, malicious code may also affect the integrity of applications and undermine trust in the organization's software systems.



7) Vulnerability Name: Missing Encryption of Sensitive Data

CWE/CVE: CWE-311

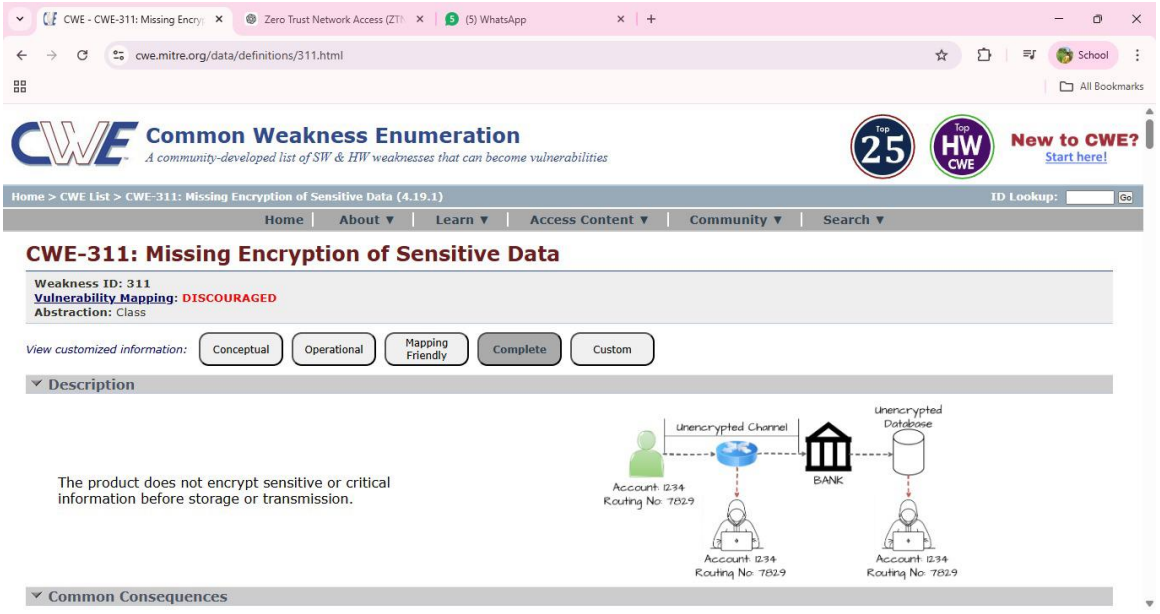
OWASP/SANS Category: A06:2025-Insecure Design

Description:

Missing Encryption of Sensitive Data occurs when an application or system transmits or stores confidential information without using proper encryption mechanisms. Sensitive data such as user credentials, financial records, personal information, or internal system details may be exposed in plain text. If this data is intercepted during transmission or accessed by unauthorized users, attackers can easily read and misuse the information. This vulnerability often arises due to poor security configuration or failure to implement secure communication protocols.

Business Impact:

The absence of encryption can lead to unauthorized disclosure of sensitive information, resulting in data breaches and identity theft.Attackers may intercept or access confidential data and use it for malicious purposes such as fraud or unauthorized system access. For organizations, this may result in financial losses, regulatory penalties, and serious damage to their reputation and customer trust. Implementing strong encryption mechanisms is essential to protect sensitive data from unauthorized access.



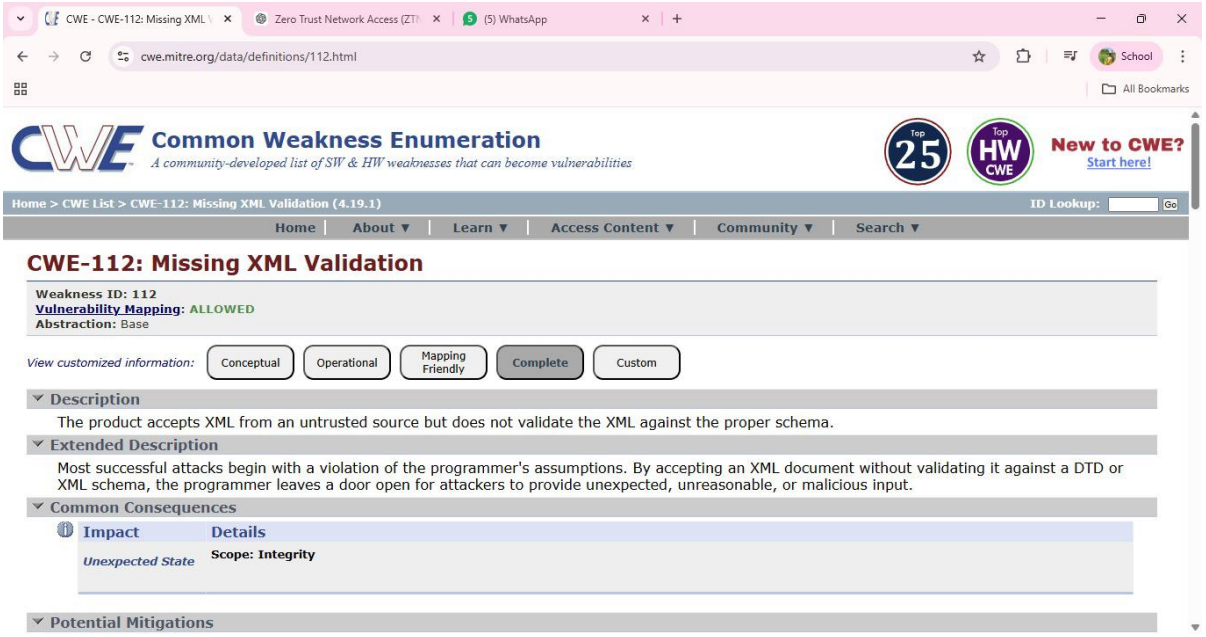
8) Vulnerability Name: Missing XML Validation

CWE/CVE: CWE-112

OWASP/SANS Category: A05:2025-Injection

Description:
Missing XML Validation occurs when an application processes XML input without properly validating its structure or content. XML is widely used for data exchange between systems, and if proper validation mechanisms are not implemented, attackers may send specially crafted XML data to manipulate application behavior. Without validation, the system may accept malicious or malformed XML input that can lead to security vulnerabilities such as XML injection, data manipulation, or unauthorized access to system resources.

Business Impact:
If XML inputs are not properly validated, attackers may exploit this weakness to alter application data, bypass security checks, or disrupt normal system operations. This can lead to data integrity issues, service interruptions, and potential exposure of sensitive information.For organizations, such incidents may result in operational disruptions, financial losses, and reduced trust from customers or partners due to compromised system security.



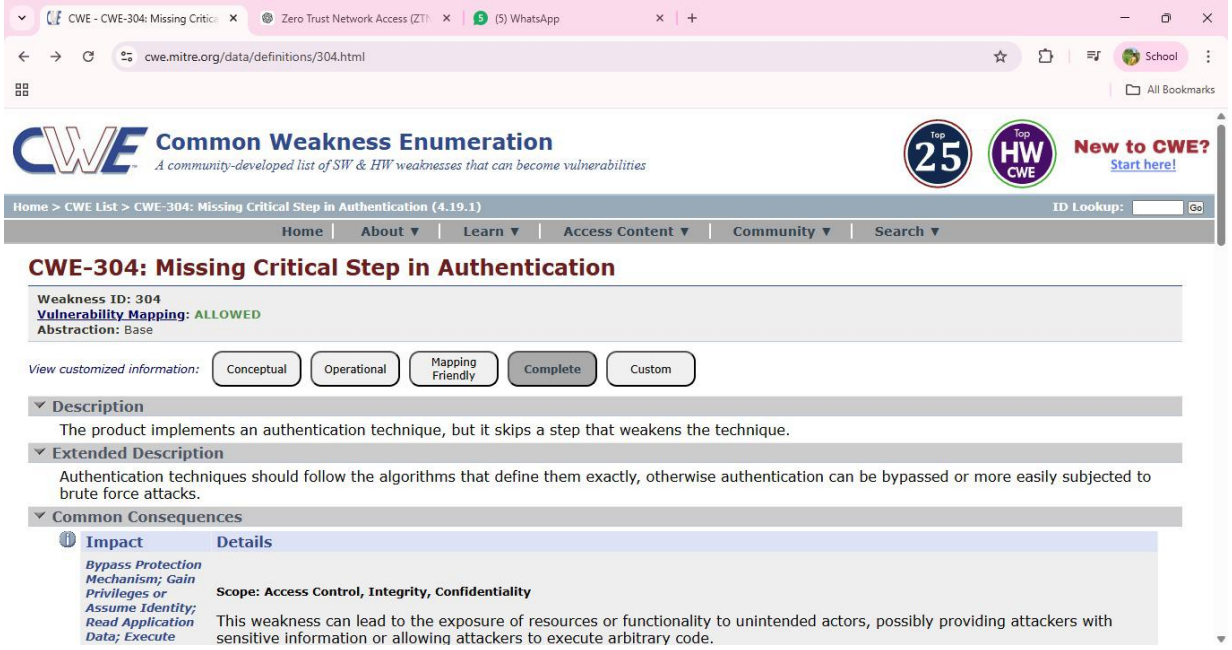
9) Vulnerability Name: Missing Critical Step in Authentication

CWE/CVE: CWE-304

OWASP/SANS Category: A07:2025-Authentication Failures

Description:
Missing Critical Step in Authentication occurs when an application fails to enforce an essential step in the authentication process required to verify a user's identity. This may happen when security mechanisms such as multi-factor authentication, verification tokens, or session validation are skipped or improperly implemented. As a result, attackers may bypass authentication controls and gain unauthorized access to protected resources or user accounts. Such vulnerabilities often arise due to poor authentication logic or incomplete implementation of security checks.

Business Impact:
If critical authentication steps are missing, attackers may successfully bypass login protections and gain unauthorized access to sensitive systems or user accounts.This can lead to data breaches, unauthorized transactions, and compromise of confidential information. For organizations, the impact may include financial losses, legal consequences, and damage to their reputation due to the failure to properly protect user authentication processes.



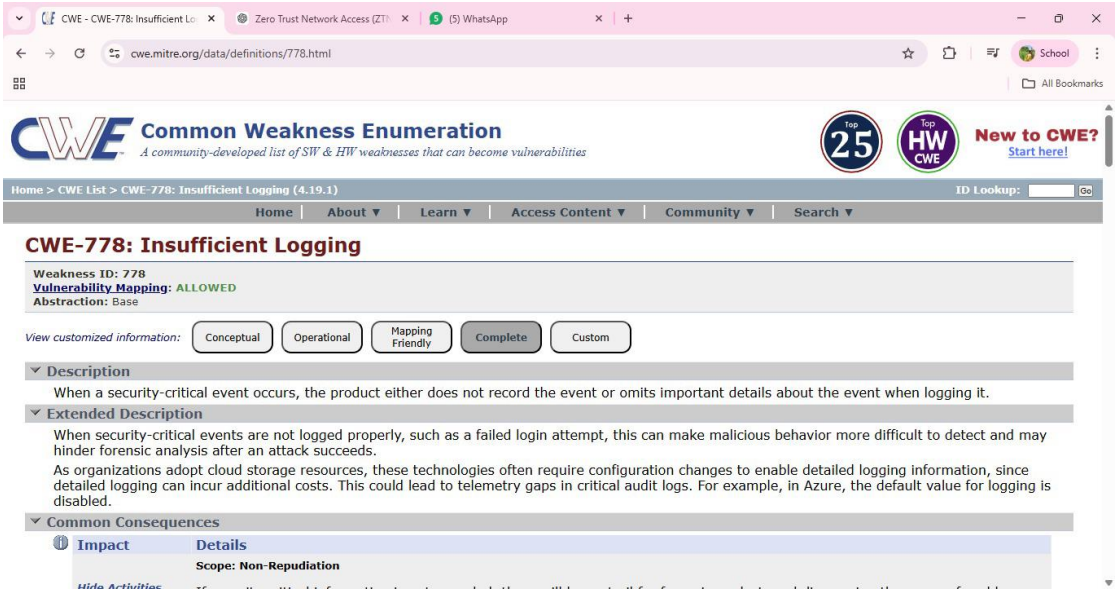
10) Vulnerability Name: Insufficient Logging

CWE/CVE: CWE-778

OWASP/SANS Category: A09:2025-Security Logging and Alerting Failures

Description:
Insufficient Logging occurs when an application or system fails to properly record security-related events such as login attempts, access requests, system errors, or configuration changes. Without adequate logging mechanisms, it becomes difficult to detect suspicious activities, unauthorized access attempts, or potential security breaches. Attackers may exploit this weakness to perform malicious actions without leaving sufficient evidence for administrators to identify or investigate the incident.

Business Impact:
Lack of proper logging can significantly delay the detection of security incidents and make it difficult for organizations to respond effectively to cyber threats. Without accurate logs, identifying the source and impact of an attack becomes challenging, which may result in prolonged system compromise or data breaches. This can lead to operational disruptions, financial losses, regulatory compliance issues, and damage to the organization's reputation.



This is stage 1 in the context of web application testing and
security we take help from

OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most critical web application security risks. Understanding these risks is essential for ensuring the security of web applications.

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615

REPORT: -

1) **Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection Severity: -** MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non- compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1 As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam) Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols. Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) Vulnerability Name: - 46180 - Additional DNS Hostnames Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure.

Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) Vulnerability Name: - 39446 - Apache Tomcat Detection Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8) Vulnerability Name: - Device Type Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network

management, optimization, and ensures that the right security measures are in place for each device type.

Stage-3

Report: -

Title: - Implementing Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

• Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is an IT security framework that provides secure remote access to an organization's internal applications and data based on clearly defined access control policies. Unlike traditional Virtual Private Networks (VPNs), which grant users broad access to the entire network, ZTNA operates on a "never trust, always verify" principle. It grants users access only to the specific applications they need, and only after their identity and device have been verified.

ZTNA is a critical component of modern security architecture. It helps organizations move away from the concept of a trusted internal network and an untrusted external network (the "castle- and-moat" model). By hiding the internal network from the internet and establishing one-to-one, encrypted connections between users and applications, ZTNA drastically reduces the attack surface and stops common threats like lateral movement by attackers.

• The ZTNA Access Cycle

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy for every access request. It typically consists of the following steps:

1. User Request: A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an internal code

repository).

2. Identity and Device Verification: Before any connection is established, the ZTNA solution verifies who the user is (via multi-factor authentication, or MFA) and checks the security posture of their device. This includes ensuring the device has up-to-date antivirus, a healthy firewall, and is not compromised.
3. Policy Enforcement: The ZTNA solution checks the access policy. Does this specific user, with this specific device, have permission to access the requested application at this specific time?
4. Establish Secure Connection: If the policy allows access, the ZTNA solution creates a highly secure, encrypted micro-tunnel between the user's device and the target application. Crucially, the user never gains access to the underlying network, only to the application itself.
5. Continuous Monitoring: The ZTNA solution continues to monitor the connection for anomalies. If the user's behavior becomes suspicious or their device posture changes, the connection can be terminated in real-time.
6. Logging and Analytics: All access attempts, successful and failed, are logged and analyzed. This data is used for auditing, threat hunting, and refining access policies.

• Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-native security platform that delivers its services entirely from the cloud, eliminating the need for on-premises hardware like VPN concentrators. For ZTNA, Zscaler offers Zscaler Private Access (ZPA) . ZPA is a service that provides seamless, identity-based access to private applications without ever placing users on the network.

Zscaler ZPA operates on a simple principle: the application is "inside" the Zscaler cloud, and the user connects to it there. It collects data from a variety of sources, including:

1. Identity Providers (IdP): Such as Azure AD, Okra, or Ping Identity, to verify user identities.
2. Device Posture Partners: Such as CrowdStrike, Tanium, or Microsoft Defender for Endpoint, to check the health of the endpoint.
3. Business Applications: The internal web apps, file servers, and legacy applications hosted in data centers or public clouds (e.g., AWS, Azure).
4. Zscaler App Connectors: Lightweight software components deployed in the data center or cloud that initiate outbound connections to the Zscaler cloud, making internal servers invisible to the internet.

Zscaler then enforces policies based on this data, including:

1. Identity-Based Access: Policies are built around user and group identities, not IP addresses.
2. Application Segmentation: Users are granted access to specific applications, not entire subnets.
3. Least Privilege Access: Ensures users have the minimum level of access required to perform their jobs.

• **The Zscaler ZTNA Cycle**

The Zscaler ZTNA cycle is the practical application of the ZTNA principles using the Zscaler cloud. The cycle typically consists of the following steps:

1. User Login and Authentication: A user attempts to access an internal application. They are redirected to their organization's Identity Provider (IdP) for authentication and MFA.
2. Device Posture Check (Integration): Zscaler checks with integrated endpoint protection tools to ensure the device is compliant with security policies.
3. Policy Lookup and Decision: The Zscaler cloud evaluates the request against the defined access policies. It verifies that the user, device, and context (time, location) are authorized for that specific application.
4. Establishing the Micro-tunnel: Once authorized, the Zscaler cloud instructs the user's Zscaler Client Connector and the appropriate Zscaler App Connector in the data center to establish an encrypted connection. The user is now connected to the application.
5. Traffic Inspection (Optional): For sanctioned applications, Zscaler can optionally inspect the traffic for data loss prevention (DLP) or to detect malware.
6. Logging and Analytics: All activity is logged in the Zscaler cloud portal for reporting, threat hunting, and compliance.

• **MISP (Malware Information Sharing Platform) Integration**

While Zscaler is a primary access control tool, it can be enhanced by integrating with threat intelligence platforms like MISP.

1. Threat Intelligence Feed: MISP can aggregate and share threat intelligence about malicious domains, IPs, and URLs. This list of indicators of compromise (IOCs) can be fed into Zscaler's cloud.
2. Proactive Blocking: If a user, even one authorized by ZPA, attempts to access a known malicious site that has been flagged by the MISP feed, Zscaler Internet Access (ZIA) can block the request, preventing a potential infection.
3. Enhanced Visibility: Security teams can use MISP to cross-reference Zscaler logs. If a user's behavior is anomalous, the team can check MISP to see if the destination IP or domain is associated with a known threat actor or campaign.

• Your College Network Information

This infrastructure presents a large attack surface, especially with the need for remote learning and

administrative access. The network includes:

- Core routers and switches
- Distribution routers and switches
- Wireless access points
- Firewalls and Intrusion Detection Systems (IDS)
- Internal Application Servers: Hosting the student information system, library resources, research data repositories, and administrative portals.
- Legacy VPN Concentrator: Currently providing broad network-level access for faculty and staff working remotely.

The need for ZTNA arises from the limitations of the current VPN model:

- Over-permissioned Access: Once on the VPN, a faculty member's compromised laptop could potentially scan and attack the entire internal network (lateral movement).
- Hidden Applications: Some research applications need to be accessed by external collaborators without granting them full network access.
- User Experience: The legacy VPN can be slow and cumbersome, often requiring users to route all their internet traffic through the university.

• How you think you deploy ZTNA using Zscaler in your college

To deploy Zscaler ZTNA (ZPA) in your college, you would start by identifying the specific applications that need to be secured and the user groups that need access to them. This is a shift from securing the network to securing access to applications.

The plan would need to include the following:

1. Application Discovery: Catalog all internal applications (e.g., ERP, library system, research servers, file shares) and identify which ones are currently exposed via the VPN.
2. User Segmentation: Define user groups (e.g., Students, Faculty - Research, Faculty - Admin, IT Staff, External Collaborators) and the specific applications each group needs.
3. Deploying Zscaler App Connectors: Install lightweight App Connector VMs in the university's data center. These connectors will establish outbound connections to the Zscaler cloud, making the application servers invisible to the public internet.
4. Integrating Identity Provider: Connect Zscaler to the university's existing Identity Provider (e.g., Microsoft Azure AD) to leverage current usernames, passwords, and MFA policies.
5. Configuring Access Policies: Create granular policies in the Zscaler admin portal. For example: "The 'Faculty' group can access the 'ERP Application' from any device that has antivirus enabled, after MFA."
6. Deploying Zscaler Client Connector: Students, faculty, and staff will install the Zscaler Client Connector on their laptops and mobile devices. This small client intelligently routes traffic for private applications through ZPA and public traffic through ZIA.

• **Threat Intelligence**

In the context of Zscaler and ZTNA, threat intelligence is used to understand who is trying to access what, and from where. It helps move beyond simple identity checks to a more contextual understanding of risk.
Sources include:

1. Zscaler Cloud Logs: Internal logs provide real-time data on who is accessing which applications, from which locations, and on what devices.
2. External Threat Feeds (MISP): Information about new malware campaigns, phishing kits, or command-and-control servers being used by attackers.
3. Identity Provider Logs: Anomalies in login attempts, such as a user logging in from two geographically impossible locations in a short time, can signal a compromised account.

This intelligence is used for:

1. Adaptive Access Control: If threat intelligence suggests a user's location is high-risk, Zscaler can step-up authentication requirements or block access entirely.
2. Hunting for Compromised Accounts: Analysts can use Zscaler logs to see if a user is suddenly accessing applications they never have before, which could be a sign of credential theft.
3. Blocking Malicious Communication: Threat intelligence feeds can be used by Zscaler Internet Access (ZIA) to block outbound connections to known malicious sites, even if they originate from a user inside the university.

• Incident Response (Adapted for ZTNA)

Incident response in a ZTNA model is faster and more targeted because the environment is inherently more controlled.

1. Detection: The SOC team detects an anomaly. For example, a faculty account is downloading an unusually high volume of data from a research server at 3 AM. Zscaler logs provide the exact details: the user, the device, the application, and the amount of data transferred.
2. Containment: The SOC team can instantly isolate the user. In the Zscaler portal, they can simply deactivate that user's access or block their specific device. Because there is no network- level access, this action immediately severs all connections to every application, preventing lateral movement.
3. Eradication: The compromised device is taken offline for malware scanning and cleaning by the IT helpdesk.
4. Recovery: Once the device is clean and the user's password is reset, the Zscaler policy is re- enabled, granting the user access again.
5. Post-incident review: The security team analyzes the logs to understand how the account was compromised (e.g., a phishing email) and updates Zscaler policies, perhaps by adding a block for similar malicious domains or tightening access rules for that specific research application.

Benefits of this incident response approach:

1. Near-Instant Containment: Actions take seconds in a cloud dashboard, not minutes or hours configuring firewall rules.
2. No Lateral Movement: The attacker is contained to the single compromised

application, protecting the rest of the university's network.

3. Granular Forensics: Zscaler provides a detailed audit trail of every connection, making investigations faster and more accurate.
4. Compliance: This model helps demonstrate compliance with data protection regulations by proving that access to sensitive student or research data is tightly controlled and audited.

• **Understanding about the tool (Zscaler ZPA)**

Zscaler Private Access (ZPA) is a cloud service that embodies the ZTNA principle of "connect a user to an app, not the network." Here are the key things to understand:

1. It is "Application-Centric," Not "Network-Centric": You define policies based on applications (e.g., "SAP Server 01"), not network constructs like IP subnets. This aligns security with how businesses actually operate.
2. It Hides the Network: ZPA uses App Connectors inside your data center that only make *outbound* connections to the Zscaler cloud. Your internal servers never need to open inbound firewall ports, making them invisible to port scanners and attackers on the internet.
3. It uses a "Dark Cloud" Approach: To an external scanner, the organization's applications simply don't exist. They only become visible to authorized users after a multi-step verification process.
4. It Provides a Superior User Experience: Users don't have to mess with clunky VPN clients. The Zscaler Client Connector works silently in the background. For web apps, access can even be agentless, requiring only a modern browser.
5. It is Inherently Scalable: Because it's a cloud service, ZPA scales instantly to handle thousands of concurrent users, unlike a legacy VPN appliance that needs to be manually upgraded**.**

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 introduced the pivotal concept of Zero Trust Network Access (ZTNA) and its implementation using Zscaler Private Access (ZPA). It demonstrated a paradigm shift from traditional VPN-based network access to secure, identity-based user-to-application connectivity. The solution showcased the power of hiding internal applications from the internet, enforcing granular access policies, and eliminating lateral movement. This underscores the need for modern, proactive cybersecurity strategies in an era of remote work and cloud adoption

Considering the future scope, **Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. **AI-Driven Zero Trust (AI-ZTA):** Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.
2. **Integration with Edge Computing and IoT:** As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.
3. **Identity-Centric Everything:** The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including **continuous behavioral biometrics** (keystroke dynamics, gait analysis)
   and **decentralized identity** solutions using blockchain, ensuring that the user behind the session is verified at all times.
4. **Convergence with SASE Architecture:** Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location.

5. **Zero Trust for Operational Technology (OT) and Critical Infrastructure:** Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical infrastructure. Future scope includes air-gapped Zero Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.
6. **Automated Threat Hunting and Response:** Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, isolate affected systems, and even roll back malicious changes.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END